

Escenario

Escenario

Usted forma parte del equipo de seguridad del Hospital Retórico y llega al trabajo una mañana. En el suelo del aparcamiento, encuentra una memoria USB con el logotipo del hospital impreso en ella. No hay nadie más cerca que pueda haberlo tirado, así que decide recogerlo por curiosidad.

Lleva la memoria USB a su oficina, donde el equipo tiene instalado un software de virtualización en una estación de trabajo. El software de virtualización se puede utilizar para este mismo propósito porque es una de las únicas formas de investigar con seguridad una memoria USB desconocida. El software funciona ejecutando una instancia simulada del ordenador en la misma estación de trabajo. Esta simulación no está conectada a otros archivos o redes, por lo que la unidad USB no puede afectar a otros sistemas si resulta estar infectada con software malicioso.

La unidad de Jorge contiene una mezcla de archivos personales y relacionados con el trabajo. Por ejemplo, contiene carpetas que parecen almacenar fotos familiares y de mascotas. También hay una carta de nueva contratación y un horario de turnos de los empleados.

Scenario

You are part of the security team at Rhetorical Hospital and arrive at work one morning. On the floor of the parking lot, you find a USB flash drive with the hospital logo printed on it. Nobody else is around who could have dropped it, so you decide to pick it up out of curiosity.

You take the USB flash drive to your office, where the team has virtualization software installed on a workstation. Virtualization software can be used for this exact purpose because it is one of the only ways to safely investigate an unknown USB flash drive. The software works by running a simulated instance of the computer on the same workstation. This simulation is not connected to other files or networks, so the USB drive cannot affect other systems if it turns out to be infected with malicious software.

Jorge's drive contains a mix of personal and work-related files. For example, it contains folders that appear to store family and pet photos. There is also a new hire letter and an employee shift schedule.

Ejercicio de USB en el estacionamiento

Ejercicio de USB en el estacionamiento

Contenidos	Escriba 2 o 3 oraciones sobre los tipos de información que se encuentran en este dispositivo. • <i>¿Hay archivos que puedan contener información de identificación personal (PII)?</i> <i>Sí, el dispositivo contiene información de identificación personal (PII), no solo del dueño (como fotos familiares), sino también de otros empleados de la organización.</i> • <i>¿Hay archivos de trabajo confidenciales?</i> <i>Sí, hay documentos laborales confidenciales, como una carta de nueva contratación y los horarios de turnos del personal, lo que expone las operaciones del hospital.</i> • <i>¿Es seguro almacenar archivos personales junto con archivos de trabajo?</i> <i>No, definitivamente no es seguro ni una buena práctica almacenar archivos personales junto con archivos de trabajo.</i>
Mentalidad del atacante	Escriba 2 o 3 oraciones sobre cómo se podría utilizar esta información en contra de Jorge o del hospital. • <i>¿Se podría utilizar la información en contra de otros empleados?, ¿Se podría utilizar la información en contra de familiares?, ¿Podría la información proporcionar acceso a la empresa?</i> <i>Sí, saber los horarios o turnos de los empleados proporciona inteligencia crucial; un atacante podría utilizar esta información para infiltrarse física o lógicamente en el sistema sin levantar sospechas, mimetizándose en los horarios normales de trabajo. La información personal y familiar podría usarse para extorsionar a Jorge o para diseñar campañas de ingeniería social (phishing), haciéndose pasar por un familiar o un compañero de trabajo para engañarlo. Además, la carta de nueva contratación o los archivos aparentemente inofensivos podrían ser un encubrimiento: el USB podría estar infectado y diseñado para dar acceso a la red de la empresa apenas sea conectado.</i>

Análisis de riesgos

Escriba **3 o 4 oraciones** que describan controles técnicos, operativos o directivos que podrían mitigar este tipo de ataques:

Controles técnicos, operativos o directivos que podrían mitigar este tipo de ataques:

Para mitigar estos incidentes, se deben implementar diversos controles:

- **Control directivo:** Promover programas de concientización para que los empleados sepan cómo actuar ante el hallazgo de un dispositivo USB sospechoso.
- **Control operativo:** Configurar y mantener escaneos antivirus de rutina en los equipos.
- **Control técnico:** Deshabilitar la reproducción automática (AutoPlay) en todas las PC de la empresa, lo que evitaría que un malware o gusano oculto en el USB ejecute automáticamente una puerta de entrada para una amenaza persistente avanzada (APT).
- ¿Qué información confidencial podría encontrar un actor de amenaza en un dispositivo como este?, ¿Cómo se podría utilizar esa información en contra de un individuo o una organización?.

Si este dispositivo cayera en manos de un actor de amenazas, podría encontrar credenciales o archivos internos. Esta información podría usarse para acceder a sistemas críticos, chantajear a los usuarios o filtrar datos, lo que terminaría manchando gravemente la reputación de la organización.

Parking Lot USB Exercise

Parking Lot USB Exercise

Contenidos	Write 2 or 3 sentences about the types of information found on this device. • <i>Are there files that could contain Personally Identifiable Information (PII)?</i> <i>Yes, the device contains personally identifiable information (PII), not only belonging to the owner (such as family photos), but also to other employees of the organization.</i> • <i>Are there confidential work files?</i> <i>Yes, there are confidential work documents, such as a new hire letter and staff shift schedules, which expose hospital operations.</i> • <i>Is it safe to store personal files alongside work files?</i> <i>No, it is definitely not safe or good practice to store personal files alongside work files.</i>
Attacker Mindset	Write 2 or 3 sentences on how this information could be used against Jorge or the hospital. • <i>Could the information be used against other employees?</i> <i>Could the information be used against family members?</i> <i>Could the information provide access to the company?</i> <i>Yes, knowing employees' schedules or shifts provides crucial intelligence; an attacker could use this information to infiltrate physical or logical systems without raising suspicion by blending into normal work hours. Personal and family information could be used to extort Jorge or design social engineering (phishing) campaigns by impersonating a relative or coworker to deceive him. Additionally, the new hire letter or seemingly harmless files could be a cover: the USB drive could be infected and designed to grant access to the corporate network as soon as it is plugged in.</i>
Risk Analysis	Write 3 or 4 sentences describing technical, operational, or managerial controls that could mitigate these types of attacks: <i>Technical, operational, or managerial controls that could mitigate these types of attacks:</i> <i>To mitigate these incidents, several controls should be implemented:</i>

	● Managerial control: Promote awareness programs so employees know how to respond when finding a suspicious USB device. ● Operational control: Configure and maintain routine antivirus scans on workstation devices. ● Technical control: Disable AutoPlay across all company PCs, preventing hidden malware or worms on the USB drive from automatically executing an entry point for an advanced persistent threat (APT). ● What confidential information could a threat actor find on a device like this? How could that information be used against an individual or an organization? If this device fell into the hands of a threat actor, they could find credentials or internal files. This information could be used to access critical systems, blackmail users, or leak data, ultimately damaging the organization's reputation severely.
--	--